Guide de sécurité du système d’information

DataNova SARL – Direction des systèmes d’information – Version 2.1, janvier 2026

Document fictif créé pour tester un assistant RAG. Les lieux, organismes, chiffres et règles qu’il contient sont inventés.

1. Objet et périmètre

Ce guide fixe les règles de sécurité applicables à tous les collaborateurs, stagiaires et prestataires de DataNova. Il couvre les postes de travail, les serveurs, les services cloud et les applications métiers. Le non-respect de ces règles peut entraîner la suspension des accès.

Le responsable de la sécurité des systèmes d’information (RSSI) est chargé de l’application du guide. Il le révise au moins une fois par an.

2. Gestion des identités et des accès

Mesure 1 – Mots de passe

Un mot de passe compte au moins **12 caractères** et mélange majuscules, minuscules, chiffres et caractères spéciaux. Les comptes administrateurs utilisent au moins **16 caractères**. La réutilisation des 5 derniers mots de passe est interdite. L’usage d’un gestionnaire de mots de passe approuvé par la DSI est obligatoire.

Mesure 2 – Authentification multifacteur

L’authentification multifacteur (MFA) est obligatoire pour la messagerie, le VPN, les consoles cloud et tous les comptes administrateurs. Les codes par SMS ne sont acceptés qu’en secours ; la méthode recommandée est une application d’authentification ou une clé physique.

Mesure 3 – Principe du moindre privilège

Chaque utilisateur ne dispose que des droits nécessaires à ses missions. Les droits sont revus tous les **6 mois** par les responsables d’équipe. Les comptes des collaborateurs partis sont désactivés au plus tard **24 heures** après leur départ.

Mesure 4 – Verrouillage des sessions

Les postes se verrouillent automatiquement après **5 minutes** d’inactivité. Après 10 tentatives de connexion échouées, le compte est bloqué pendant 15 minutes.

3. Postes de travail et serveurs

Mesure 5 – Mises à jour de sécurité

Les correctifs de sécurité critiques sont appliqués sous **7 jours** sur les serveurs exposés à Internet et sous **30 jours** sur les autres équipements. Les systèmes qui ne reçoivent plus de mises à jour de l'éditeur sont retirés du réseau.

Mesure 6 – Chiffrement

Les disques des ordinateurs portables sont intégralement chiffrés. Les données classées « confidentiel » sont chiffrées au repos et en transit (TLS 1.2 minimum).

Mesure 7 – Logiciels autorisés

Seuls les logiciels figurant dans le catalogue de la DSI peuvent être installés. Toute demande d'ajout passe par un ticket et une validation du RSSI sous 5 jours ouvrés.

Mesure 8 – Supports amovibles

Les clés USB personnelles sont interdites. Les supports amovibles fournis par la DSI sont chiffrés et analysés par l'antivirus à chaque connexion.

4. Sauvegardes et continuité

Mesure 9 – Règle 3-2-1

DataNova applique la règle 3-2-1 : trois copies des données, sur deux supports différents, dont une copie hors site et déconnectée du réseau. Les bases de données de production sont sauvegardées **toutes les 4 heures** ; les autres serveurs une fois par jour.

Mesure 10 – Tests de restauration

Une restauration complète est testée chaque trimestre. L'objectif de reprise (RTO) est de **8 heures** et la perte de données maximale admissible (RPO) est de **4 heures** pour les applications critiques.

Données	Fréquence de sauvegarde	Durée de conservation
Bases de production	Toutes les 4 heures	35 jours
Serveurs de fichiers	Quotidienne	90 jours
Messagerie	Quotidienne	1 an
Archives comptables	Mensuelle	10 ans

5. Réseau et accès distants

Mesure 11 – Cloisonnement

Le réseau est découpé en zones : bureautique, serveurs, administration et invités. Le Wi-Fi invités n'a aucun accès aux ressources internes.

Mesure 12 – Télétravail

L'accès aux ressources internes depuis l'extérieur se fait uniquement par le VPN de l'entreprise, avec MFA. L'usage d'un ordinateur personnel pour accéder aux données de DataNova est interdit.

6. Incidents de sécurité

Mesure 13 – Signalement

Tout incident ou comportement suspect (courriel d'hameçonnage, perte d'un équipement, message d'erreur inhabituel) est signalé au support sécurité dans un délai d'**une heure**, par l'adresse securite@datanova.example ou le poste 4040.

Mesure 14 – Gestion de crise

En cas d'incident majeur, une cellule de crise réunit le directeur général, le RSSI, le DSI et le responsable juridique. Les données personnelles compromises font l'objet d'une notification à l'autorité de protection des données compétente dans les 72 heures.

7. Sensibilisation

Mesure 15 – Formation

Chaque collaborateur suit une formation de sensibilisation à son arrivée, puis une session de rappel chaque année. Une campagne d'hameçonnage simulé est menée chaque semestre ; en 2025, le taux de clic est passé de 18 % à 7 %.